

Gestion des dépendances et veille : Dependabot et ce qui reste hors radar

Une dépendance non mise à jour est une dette et un risque de sécurité. DataShare automatise la veille avec **Dependabot** (outil GitHub qui ouvre des PR de mise à jour), configuré dans `.github/dependabot.yml`, et documente dans `MAINTENANCE.md` ce qu'il ne couvre pas. Le fichier de config contient plus de règles que le tableau de `MAINTENANCE.md` : la fiche s'appuie sur le fichier réel.

Dependabot par écosystème

Toutes les entrées sont en `interval: weekly` : une vague de PR par semaine.

Écosystème	Répertoire	Préfixe de commit	Particularités
github-actions	/	ci	actions des workflows
maven	/backend	build (dépendances de dev : chore)	limite de 10 PR ouvertes
npm	/frontend	build (dépendances de dev : chore)	groupes angular et vitest, règles ignore
docker	/backend	build	ignore des majeures Java et Maven
docker	/frontend	build	ignore des majeures de Node

Chaque PR Dependabot passe par la CI complète, avec les mêmes *required checks* que les autres.

Préfixes de commit : pourquoi ces choix

Le titre d'une PR doit respecter Conventional Commits (job `commitlint`, voir la fiche `ci-github-actions.md`). Dependabot construit son titre avec le préfixe configuré :

```
commit-message:
  prefix: build
  prefix-development: chore
```

- `prefix` : dépendance **de production** → `build: bump ...`.
- `prefix-development` : dépendance **de développement** (outils comme `eslint`, `prettier`, `cypress`) → `chore: bump ...`.
- Les actions GitHub reçoivent `ci`, car elles font partie du pipeline.

Sans ce réglage, Dependabot génère des titres que `commitlint` rejeterait. Les commits réels le montrent : `build: bump the angular group ... (#97)`, `ci: bump github/codeql-action ... (#94)`, `chore: bump eslint ... (#99)`.

Groupes et règles ignore

Deux mécanismes de la config npm et docker, chacun justifié par un commentaire du fichier :

```
groups:
  angular:
    patterns: [ "@angular/*" ]
```

- **Groupe angular** : les paquets `@angular/*` exigent tous la même version (peer dependencies strictes). Montés un par un, chaque PR échouait sur `ERESOLVE` (#22, #26, #34, #36). Groupés, une seule PR les monte ensemble. Même logique pour `vitest` et `@vitest/*`.
- **ignore des versions majeures** : `vitest` reste en 4.x tant qu' `@angular/build` ne supporte pas `vitest 5`. Côté Docker, Java reste sur **21 (LTS, Long Term Support)** tant que 25 n'est pas la cible (24 n'est pas LTS), et Node sur une version paire LTS (24).

Ces `ignore` portent une **condition de retrait** dans leur commentaire : ils sont temporaires.

Niveaux de risque

Type	Traitement (<code>MAINTENANCE.md</code>)
patch (<code>x.y.z</code>)	revue rapide, merge si CI verte
minor (<code>x.Y.z</code>)	lire le changelog, merge si CI verte
major d'une lib	PR dédiée, adaptation du code, tests renforcés
major d'un framework (Angular, Spring Boot)	PR dédiée + migration planifiée, jamais dans l'urgence

Principe : ne jamais rester sur une version hors support OSS (Open Source Software). Leçon citée : Spring Boot 3.5 et Angular 19 écartés au profit de Spring Boot 4.1 et Angular 22.

Ce qui reste hors radar automatique

Sujet	Pourquoi Dependabot ne le voit pas	Suivi
Images d'infrastructure (<code>postgres</code> , <code>silos</code> , <code>adminer</code>)	il ne surveille que les <code>Dockerfile</code> de <code>backend/</code> et <code>frontend/</code> , pas <code>docker-compose.yml</code>	manuel, alignées sur 3 fichiers (voir conteneurisation-deploiement-images.md)
Audit CVE (Common Vulnerabilities and Exposures) du back	OWASP dependency-check n'est pas câblé en CI	lancement manuel (<code>./mvnw dependency-check:check</code>)
Fin de support des frameworks	Dependabot propose des versions, pas des dates de fin de vie	vérification sur <code>endoflife.date</code> avant une montée majeure

Nuance : les **Dependabot security alerts** (paramètre du dépôt, hors `dependabot.yml`) signalent les CVE des dépendances Maven, npm et Actions sans bloquer la CI. Elles couvrent en partie ce que l'audit manuel couvre.

Dans DataShare

- Configuration : [.github/dependabot.yml](#) .

- Procédures, niveaux de risque, audit manuel : [MAINTENANCE.md](#) §1.
- Politique de sévérité : [SECURITY.md](#) §3 et §5.
- Point à jour : [MAINTENANCE.md](#) ne mentionne ni `prefix-development` , ni les groupes, ni les `ignore` , qui n'existent que dans le fichier de config.

À retenir

1. Dependabot ouvre chaque semaine des PR par écosystème (Actions, Maven, npm, Docker) ; chacune passe par la CI complète.
2. Les préfixes (`build` , `chore` pour le dev, `ci`) existent pour que les titres respectent `commitlint` .
3. Groupes et `ignore` viennent de problèmes réels (peer dependencies strictes, LTS) et portent leur condition de retrait dans un commentaire.
4. Hors radar : images du compose, audit OWASP du back, dates de fin de support : suivis à la main.
5. Une majeure de framework n'est jamais traitée dans l'urgence : PR dédiée et planifiée.